STRAVYX

Australia's On-Demand Drone Services Network

Independent review of how Stravyx connects drones

Support with conditions | Cloud API + manual unchanged | Findings A-01 to A-10

Stravyx Pty Ltd ACN 696 964 271 | 16 Aug 2026 | CONFIDENTIAL

Source: docs/dji-live-ops-challenger-findings.md. Reviewer: architecture-challenger (independent of the original architect). Authority: dji-integration-architecture.md, ADR 0005, glossary in dji-live-ops-path-comparison.md.

Verdict: Support with conditions. The recommended path is still right. Several safety and honesty gaps must close before live drone links or automatic photo upload go to production. Does not change: Cloud API + manual; FlightHub 2 still later; no NestJS/MQTT code until Phase 1B + privacy approval.

1. Reminder glossary

Term	Plain meaning
ReOC	The licensed drone company (Alex's business).
Workspace	The company room a remote controller logs into.
Gateway	The remote controller (or dock) that talks to the internet.
STS	A short-lived upload key so photos go into our storage without our permanent password.
Quarantine / Release	Photos land as held; the operator confirms they belong to this job; then the customer can download.
Manual path	No live drone link: tap status and upload files by hand.
SoT	System of record - the official answer. For bookings and files: Stravyx.

2. What this review was for

An independent reviewer tried to break the plan: drones report to Stravyx (Cloud API); everyone else uses manual upload. They were not asked to agree. They were asked: where could two companies see each other's jobs? Where could photos land on the wrong booking? Where are we promising something the spare tyre cannot actually do?

Bottom line: keep the plan. Tighten ten points before we turn on live ingest.

3. How to read each finding

1. Picture - a shop-floor analogy.
2. Problem - what can go wrong.
3. Recommended fix - the one we would do if forced to pick.
4. Two alternatives - when they are better or worse.
5. Who decides - engineering can proceed, or a human must choose.

Severity	Meaning
BLOCKER	Do not turn on live MQTT / auto-upload until this is designed.
HIGH	Can ship a smaller slice, but must not reach customers in a half-done form.
MEDIUM	Shape the design now so we do not paint ourselves into a corner.

4. A-01 - Keep each drone company's room private (BLOCKER)

Picture. Two licensed operators, Alex and Brooke, both use Stravyx. Each remote controller must only see its company's drones and jobs - like two hotels that must not share room keys.

Problem. MQTT access lists are necessary but not enough. Login, list my devices, and give me an upload key are ordinary web requests. A valid controller login could, in a sloppy design, list another company's aircraft or ask for an upload key into the wrong cupboard.

Recommended fix (S2). Give each ReOC its own logical Cloud API workspace. The server decides which room you are in from the login token - never from a company ID the app typed in the URL. The same rule applies to upload keys, photo callbacks, and radio topics. Moving a drone between companies is a deliberate, audited handover, not a silent re-pair.

Alternative 1: one shared DJI room, Stravyx filters every query (worse if one filter is missed). Alternative 2: a completely separate server per large customer (cost explodes at marketplace scale). Who decides: Yes. Per-company rooms vs accept shared-room risk.

5. A-02 - The handset that asks for the upload key must own the aircraft (BLOCKER)

Picture. Alex assigns aircraft SN-123 to a roof job. The remote controller is what asks Stravyx for a short-lived upload key. Controllers can be re-paired to a different drone.

Problem. Binding the aircraft to the job at allocated does not prove that this controller currently controls that aircraft. A stale pairing or a replayed request could mint job-scoped keys for the wrong device.

Recommended fix (between S2 and S3). A short-lived capture session: this company + this controller + this aircraft + this job, with a freshness check. Upload keys may only write into a folder named after that session. The upload-finished report must carry the same session id.

Alternative 1: challenge the controller at every key request (weaker for reconnects). Alternative 2: session on the dock only (worse for Pilot 2 handsets that swap drones). Who decides: Yes. Approve the session model and how fresh topology must be.

6. A-03 - Manual upload is a spare tyre, not a second sports car (HIGH)

If the live radio is down, Alex can still finish the job: tap status and upload photos. The customer still gets files. They will not get a live map pin. The written rule that every customer-visible outcome must work on the manual path over-promises live tracking.

Recommended fix (S1). Narrow the promise: manual always delivers booking, accept, progress labels, and raw photos. Live map is optional and labelled (live / manual status / unavailable). Never let is the drone online change who wins the job or the price.

Alternative 1: phone GPS as a vendor-neutral map pin (privacy, battery, unapproved mobile app). Alternative 2: borrow FlightHub tracking (excludes non-DJI, second cloud). Who decides: Yes. Live-ops A promises live-map parity, or only completion and delivery parity?

7. A-04 - Allocated is planning, not this flight is live (HIGH)

On Monday Alex assigns an aircraft to Thursday's roof job. On Tuesday he still needs that aircraft for a different site. If assigned to Thursday means locked as the live flight forever, Tuesday cannot use it, and Thursday's stale lock is a safety bug.

Recommended fix (S2). Keep planned assignment. Use the capture session (A-02) as the only lock that authorises live upload and live tracking.

Alternative 1: bind only minutes before take-off. Alternative 2: one table with planned vs active flags (planning and security stay tangled). Who decides: Yes. Must we support several future scheduled missions on the same aircraft?

8. A-05 - Winning the job must be all-or-nothing (HIGH)

First-to-accept is a race. The database must record one winner, update the job, and write the history together. Today those updates are separate steps in the demo API. A unique index stops two accepted offers, but not a broken half-record.

Recommended fix: one database function per command (accept, change status, release photos) that checks expected state, writes everything in one transaction, and ignores a retry with the same idempotency key. Alternative 1 (wait for NestJS) leaves the Edge demo inconsistent. Alternative 2 (nightly cleanup) is unacceptable. Who decides: No. Follows existing marketplace rules.

9. A-06 - One way to name a file in storage (HIGH)

The demo column is storage_path. The long-term model mentions s3_key. The architecture proposes provider + object_key. Three names for one idea.

Recommended fix (S0). Store a provider-neutral address: provider, bucket, object key, version, region, sha256. Manual upload can still use today's storage. Drone auto-upload later adds an S3/MinIO adapter without changing the API the apps see. Download links are always minted by our server.

Alternative 1: start on Australian S3 from S0. Alternative 2: stay on current storage, then bulk-move before auto-upload. Who decides: Yes. Which storage provider, and do we migrate or start on the final cupboard?

10. A-07 - Upload finished texts can get lost (HIGH)

The drone uploads a photo, then sends a postcard. If we only listen for postcards, a lost postcard means the file sits in the cupboard forever. Ignoring a duplicate postcard does not find a missing one.

Recommended fix (S3). Durable inbox of postcards; identify each object by bucket and version; periodically walk the session folder and create held records after hash checks. Closing a session includes we expected these files. Who decides: No. Use inbox + folder scan.

11. A-08 - Held for the operator is not the same as safe to open (HIGH)

Quarantine today means the customer cannot download yet. It does not mean we checked that the file is a real photo, not a renamed virus, not a huge junk blob. Signing a download link to a held file can still harm the customer's computer.

Recommended fix (S0). Land files in a private, non-executable area. Enforce size limits, allowed types, and magic-byte checks. Hash. Scan for malware before Release. Previews generated in isolation. Keep a retention / legal-hold rule. Who decides: Yes. Formats, size limits, scanner, retention.

12. A-09 - Do not force manual upload to pretend it is a live drone (MEDIUM)

If we invent one giant flight-provider plug that must do online, stream positions, and auto-upload, the manual plug will return fake success or empty topology.

Recommended fix (S1). Split the plugs: status reporter, file ingress, device connector, live position source. Manual implements the first two. DJI implements all four. Who decides: Yes. Changing this contract needs Program Design (named in ADR 0005).

13. A-10 - We have not yet proved the bill (MEDIUM)

We deferred FlightHub 2 because per-device seats looked expensive. We have not written down what it costs us to run a highly available radio broker, storage, and night-time support at 1, 100, and 1,000 devices versus a current FlightHub Business quote.

Recommended fix (before paid S2). Three workload models comparing our Cloud API operating cost, FlightHub Business (verified quote), and manual-only baseline. Keep FlightHub deferred unless the numbers change Live-ops A. Who decides: Yes. What cost/risk threshold lets us go past a pilot?

14. In what order

When	Close these
Before customers download real files (S0)	A-05; A-06; A-08
While designing S1	A-03 honest spare-tyre promise; A-09 split plugs
Before live bind (S2)	APP 8; A-01; A-04; A-05; a pilot cost check (A-10)
Before automatic photo upload (S3)	A-02 capture session; S3 storage adapter (A-06); A-07; A-08 on device files

Later	Phone map pins; scale tuning; FlightHub for maps/3D

Existing gates still apply: release state machine, APP 8 / DPIA, capture-session attribution, per-controller radio passwords, and no money/address leaks tests. This review adds the ten items above; it does not replace those.

15. What we will not do

- Trust a company id typed in a URL.
- Hand out upload keys from whatever was last paired.
- Treat upload finished postcards as the only proof a file exists.
- Let customers download held files before type/malware checks.
- Make the manual path invent fake live-drone data.
- Rank who gets the job by whose drone is online.
- Start NestJS, MQTT, or FlightHub before the existing Phase 1B and privacy gates.
- Change the recommendation: drones still report to Stravyx; manual remains the spare tyre.

16. Human decisions still open

1. Per-ReOC Cloud API rooms vs one shared room with filtering (A-01).
2. Capture-session rules and how fresh pairing must be (A-02).
3. Live-ops A: live map promised, or only completion + files (A-03).
4. Whether aircraft planning must support several future jobs (A-04).
5. Storage provider and whether we migrate (A-06).
6. File types, size limits, scanner, retention (A-08).
7. Split flight-provider contracts (A-09 / Program Design).
8. Cost threshold past a Cloud API pilot (A-10).